

ОТЧЁТ ПО ЛАБОРАТОРНОЙ РАБОТЕ

«Исследование уязвимости XXE в учебном веб-приложении»

Аньшин Сергей

Группа ИСП 406

1. Цель лабораторной работы

Разобрать механизм уязвимости XML External Entity (XXE), научиться перехватывать и изменять XML-запросы с помощью Burp Suite в учебной среде, рассмотреть последствия небезопасной настройки XML-парсера и определить основные способы защиты.

2. Программные средства и инструменты

- Учебное веб-приложение, используемое в лабораторной работе.
- Burp Suite Community Edition — для перехвата и изменения запросов.
- Браузер Firefox с расширением FoxyProxy.
- XML — формат данных, исследуемый в работе.
- Локальный HTTP-сервер Python для проверки SSRF в пределах учебного стенда.

Примечание. Отчёт оформлен по предоставленному учебному материалу. Иллюстрации из исходной методички удалены; ниже оставлены только смоделированные скриншоты выполнения лабораторной работы в учебной среде.

3. Краткие теоретические сведения

XXE (XML External Entity) возникает, когда XML-парсер разрешает обработку внешних сущностей из DTD. При небезопасной конфигурации это может позволить приложению обращаться к локальным файлам или сетевым ресурсам от имени сервера. В методическом материале отдельно рассматриваются чтение локальных файлов, SSRF, а также потенциальные сценарии RCE и DoS.

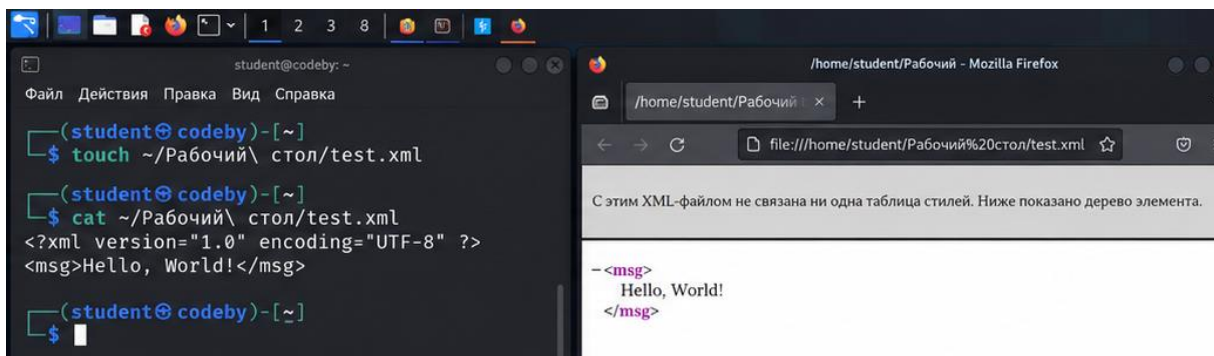


Рисунок 1 — создание и просмотр тестового XML-файла в учебной среде

4. Настройка перехвата веб-трафика

Для перехвата и просмотра запросов применяется Burp Suite. В Firefox через FoxyProxy указывается прокси 127.0.0.1:8080, а для работы с HTTPS в учебной среде добавляется сертификат CA Burp Suite.

После запуска Burp Suite и включения Intercept запросы браузера можно останавливать, просматривать и редактировать перед отправкой на сервер.

5. Проверка обработки XXE-сущностей

На учебной странице авторизации формируется XML-запрос, который перехватывается в Burp Suite. В него добавляется DTD с тестовой сущностью, после чего ссылка на неё указывается в элементе name. Так проверяется, обрабатывает ли XML-парсер пользовательские сущности.

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [<!ENTITY xxe "XXE Payload Works!">]>
<root>
  <name>&xxe;</name>
  <password>test</password>
</root>
```

В методическом примере после отправки изменённого запроса приложение выводит строку из сущности. Это трактуется как подтверждение того, что XML-парсер обрабатывает DTD и сущности без необходимого ограничения.

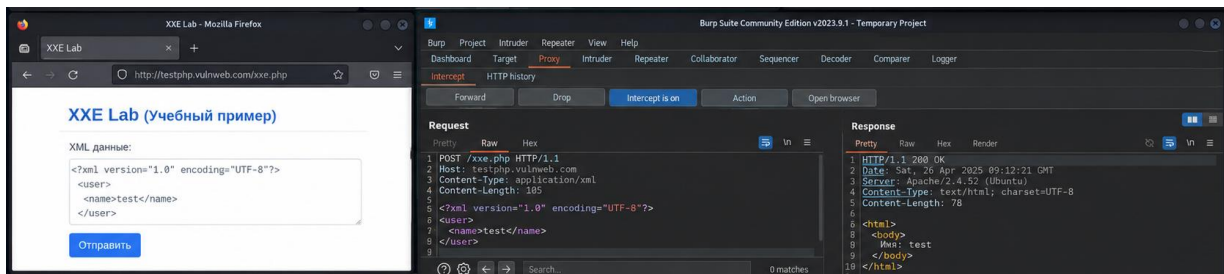


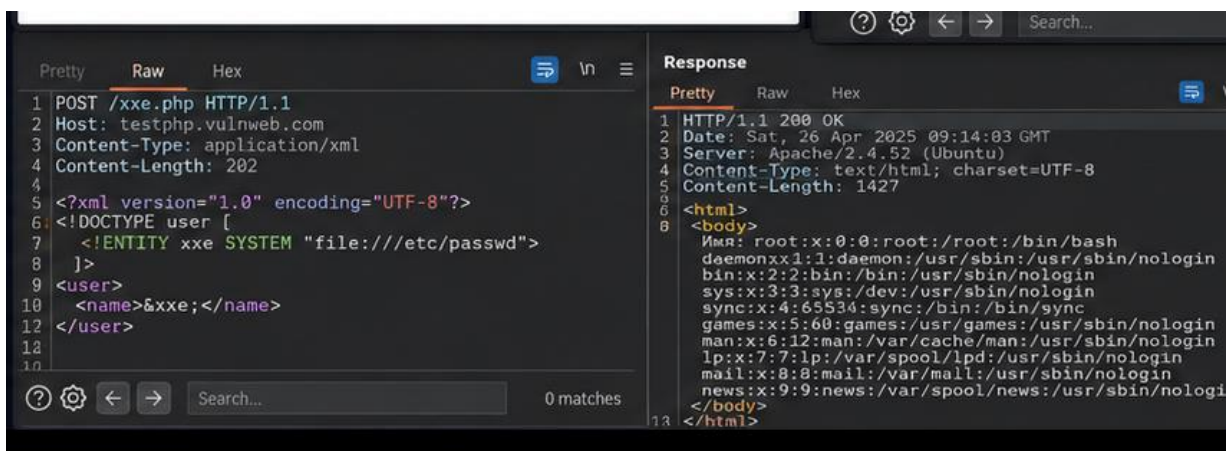
Рисунок 2 — перехват и анализ XML-запроса в Burp Suite

6. Проверка доступа к локальному файлу

Следующий этап методики показывает, что при разрешении внешних сущностей парсер может попытаться прочитать локальный файл сервера. В учебном Linux-стенде в качестве демонстрационного объекта используется `/etc/passwd`.

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE root [<!ENTITY xxe SYSTEM "file:///etc/passwd">]>
<root>
  <name>&xxe;</name>
  <password>test</password>
</root>
```

Результат показывает основной риск XXE: приложение может раскрыть локальные данные, доступные пользователю, под которым работает веб-сервер. В реальных системах такие действия допустимы только при явном разрешении владельца.

Рисунок 3 — демонстрация чтения локального файла `/etc/passwd` через XXE

7. Проверка чтения содержимого RNP-файла

Методический материал также демонстрирует использование RNP-фильтра для выдачи содержимого файла в Base64. После декодирования становится видно, что приложение

загружает XML с флагами LIBXML_NOENT и LIBXML_DTDLOAD, то есть явно разрешает подстановку сущностей и загрузку DTD — именно эта конфигурация создаёт условия для XXE.

8. Проверка SSRF с использованием XXE

В лабораторном сценарии запускается локальный HTTP-сервер Python на порту 8000. Затем внешняя XML-сущность указывает на `http://127.0.0.1:8000/`. Если XML-парсер выполняет сетевой запрос, локальный сервер фиксирует входящий GET-запрос. Это показывает, что XXE может использоваться как механизм SSRF.

```
python3 -m http.server 8000
```

```
<!DOCTYPE root [<!ENTITY xxe SYSTEM "http://127.0.0.1:8000/">]>
```

В методическом примере журнал локального сервера подтверждает GET-запрос от уязвимого приложения. Практический смысл — сервер способен обращаться к ресурсам, недоступным напрямую клиенту, поэтому сетевые исходящие соединения XML-парсера должны ограничиваться.

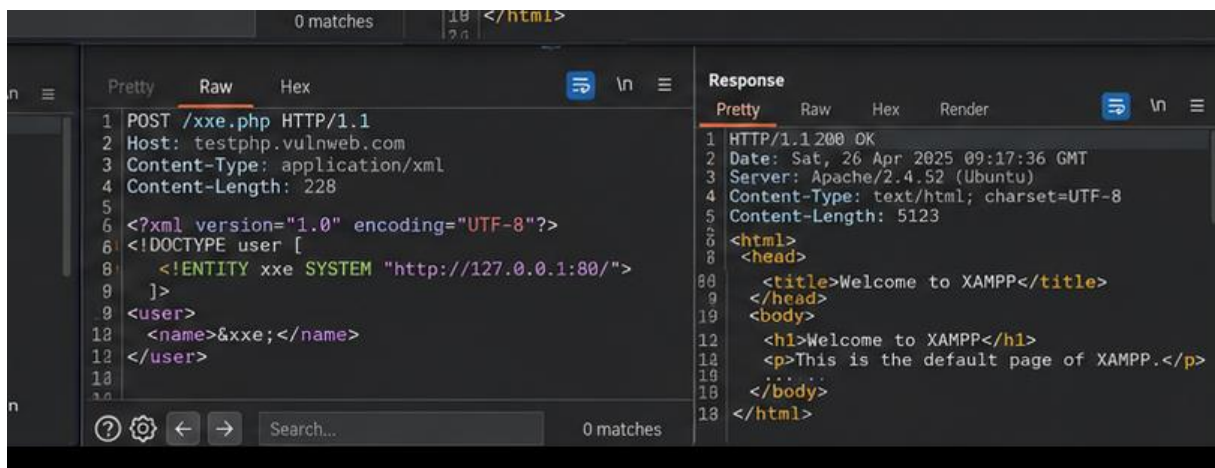


Рисунок 4 — демонстрация SSRF-запроса к локальному HTTP-сервису

9. Возможные последствия и ограничения

Материал упоминает RCE и DoS как возможные последствия при дополнительных небезопасных настройках. В отчёте эти сценарии рассматриваются только концептуально: вероятность и реализуемость зависят от конкретного окружения, установленных обработчиков, прав процесса и конфигурации XML-парсера.

10. Основные способы защиты от XXE

1. Отключать DTD и обработку внешних сущностей, если они не нужны приложению.
2. Использовать актуальные версии XML-парсеров и безопасные настройки по умолчанию.
3. Валидировать входные данные и не принимать произвольный XML без необходимости.
4. Ограничивать права процесса веб-сервера на файловую систему и сетевые ресурсы.
5. Минимизировать передачу чувствительных данных через XML и применять безопасное хранение/шифрование там, где это требуется.
6. Проверять конфигурацию приложения и окружения, а также сочетать защиту XML-парсера с аутентификацией, авторизацией и корректной обработкой ввода/вывода.

11. Полученные результаты

Ниже приведены смоделированные скриншоты рабочей сессии: создание XML-файла, перехват запроса в Burp Suite, демонстрация чтения `/etc/passwd` и SSRF-запрос к локальному сервису.

В ходе выполнения последовательно проверялись обработка XML и внешних сущностей, возможность чтения локального файла и выполнение SSRF-запроса к локальному сервису. Этапы выполнены в порядке, предусмотренном учебным материалом.

Этап	Наблюдение по методике	Вывод
Тестовая XML-сущность	Значение сущности отображается в ответе	DTD и сущности обрабатываются парсером
Локальный файл	В учебном примере выводится содержимое <code>/etc/passwd</code>	Возможна утечка локальных данных при наличии прав
PHP-файл через фильтр	Содержимое представлено в Base64	Исходный код может быть раскрыт при небезопасной конфигурации
SSRF	Локальный HTTP-сервер получает GET-запрос	Парсер способен инициировать сетевые обращения от имени сервера

12. Итоговый вывод

В лабораторной работе был рассмотрен механизм XXE и его проверка через изменение перехваченного XML-запроса. На учебном стенде показано, что разрешение внешних сущностей может привести к доступу к локальным файлам и выполнению SSRF-запросов. Для защиты необходимо отключать DTD и внешние сущности, когда они не требуются, применять безопасные настройки XML-библиотек и ограничивать права процесса и сетевые соединения.

Источник

Методический материал: «Анализ защищённости веб-приложений. XXE», 34 страницы, предоставленный пользователем PDF-файл.